Secure Enclave – Individual Design Test Document

Introduction

This document details functionality, security feature and code testing of a music storage application, designed according to a team design document.

The application design section will discuss the structural elements of the application and show a list of dependencies with justifications.

The application walkthrough section will go through use of the application and show results of testing the functionality. This will be both Create, Read, Update and Delete (CRUD) functionality, as well as security feature functionality. Security features will be linked to the Open Worldwide Access Security Project (OWASP) Top Ten Proactive controls from 2024 (OWASP, 2024).

The code testing section shows static code testing results for code functionality, programming style and security.

Application Design

The application consists of six .py files:

- main.py contains the application's main script, bringing together functions and methods from the other files.
- functions.py has login, registering and multi-factor authentication (MFA) functions.
- user_datbase.py and artefact_database.py create databases, one for user details and one for uploaded files.
- classfile.py shows three classes – User, Admin and Artefact and all the methods belonging to each.
- services.py contains the services uploaded files will be run through – a file checker, encryption, a checksum generator and a timestamp generator.

Database Design

The initial group design prioritised simplicity and ease of use. Accordingly, SQLite was the obvious choice for a database; a sqlite3 module is included in python. SQLite is considered the most popular database; its use ranges across devices (Gaffney et al., 2022)

Two databases are created, rather than two tables, separating user details from application data.

Parameterized queries are used to protect against injection attacks (Odeh and Hijazi, 2023). This security element fits under OWASP Proactive Control C3: Validate all Input and Handle Exceptions (OWASP, 2024). This control is also covered using try, except statements. Database errors messages are generic to avoid giving malicious actors system information.

Dependencies

Some packages must be installed via pip to run the application.

Package	Justification
Bcrypt	Hashes and salts passwords (Python Cryptographic Authority, 2025).
Cryptography	Fernet module used for encryption / decryption (Python Cryptographic Authority, 2025).
Pillow (PIL offshoot)	Used for image processing when displaying PDFs (Clark et al., 2025).
Pygame	A multimedia handler. Used for audio playback. (Shinners et al., 2000)
PyMuPDF (Fitz)	Extracts data from pdf files (Team PyMuPDF, 2025).

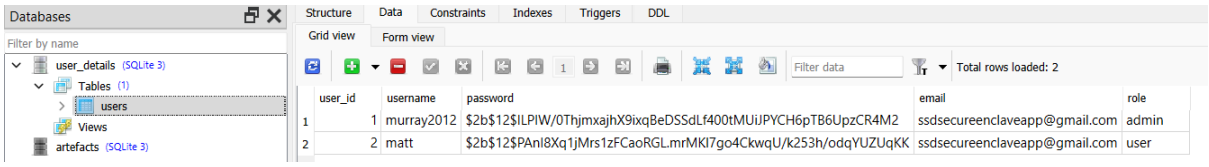
Application Walkthrough

Registration

Databases are created or checked on startup. If no admin accounts are found the welcome screen prompts creation of one. A username, password and email address are required for registration. The role is hardcoded for the first user to be admin. Successive users are only to be registered as users. Once an admin is registered the home screen only offers the option to log-in or register as a regular user.

Several security features are applied at this stage. The getPass module is used to hide passwords on screen at input for extra security (Schmidt, 2023) and is an addition to the original design. Bcrypt hashes passwords for storage (Python Cryptographic Authority, 2025). Passwords are asked to follow guidelines for appropriate strength level (Geeks for Geeks, 2022), another addition. Login attempts are limited. All these features, as well as the following login / MFA section cover OWASP Proactive Control C7: Secure Digital Identities (OWASP, 2024).

```
----- Artifact Database Initialized -----
----- User Database Initialized -----



--------------------------------------------------------------------
***** Welcome to the Essex University Secure Music Storage App. *****
--------------------------------------------------------------------


No admin accounts found. Please register the first admin.
Choose a username: murray2012
Enter your password:
Enter an email address: ssdsecureenclaveapp@gmail.com
murray2012 registered as new admin.
Enter 1 to login to an existing account, or enter 2 to create a new account? 2
To register, please enter the following details:
Username: matt
Password needs > 8 characters, < 15 character, contain a digit and a special character eg.@#!?
Password:
Enter an email address:ssdsecureenclaveapp@gmail.com
matt registered as a new user.
Continue to log in? Y/N:
```



Login

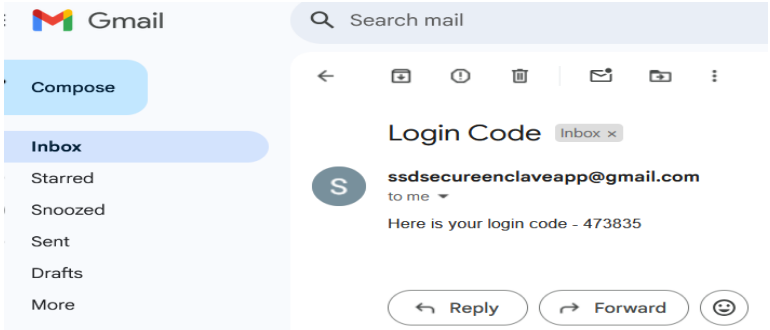
Login is done via MFA. Stage 1 is to enter the username and password. Stage two is to enter a verification code sent to the user's email address. MFA is an addition to the original application design but was deemed essential during implementation.

Login as a regular user leads to an options screen. Login as admin user leads to a option screen with extra functionality.

This is a form of Role Based Access Control (RBAC), essential for a secure platform. RBAC would be considered part of OWASP's proactive control C1: Implement Access Control (OWASP, 2024).

```
Continue to log in? Y/N: Y
Enter Username: matt
Enter your password:
Verification code sent.
Enter the verification code: 473835
Logged in as user - matt


--------------------------------------
What would you like to do?:
        1) View My Artefact Library.
        2) Access an Artifact.
        3) Add Artefact.
        4) Modify Artefact.
        5) Delete an Artefact.
        6) Update Details.
        7) Delete Account
        8) Log Out.
        :
```

```
Enter Username: murray2012
Enter your password:
Verification code sent.
Enter the verification code: 826901
Logged in as admin - murray2012
--------------------------------------
What would you like to do?:
        1) View My Artefact Library.
        2) Access My Artefacts.
        3) Add Artefact to my List.
        4) Modify my Artefacts.
        5) Delete my Artefact.
        6) Update Details.
        7) View full user list.
        8) View full artefact list.
        9) Access any Artefact.
        10) Delete any Artefact.
        11) Change any User role.
        12) Delete any User account.
        13) Log Out.
        :
```



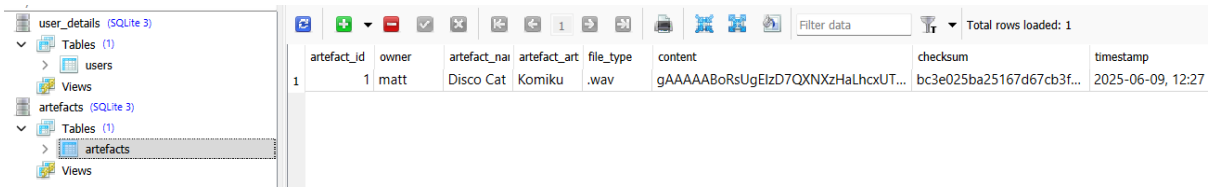
User Options

User options allow basic CRUD functionality.

Users can create, or add, music related artefacts to the database. When users add a file, it goes through several security processes before being added to the database. First, it is subject to file validation – a file type whitelist has been created, only .mp3, .ogg, .pdf, and .wav files are allowed. It is also checked for size to avoid data flood attacks; only files of up to ten megabytes are allowed. This process covers OWASP C3 (OWASP, 2024) and protects against the upload of files that could act on the system. Preventing data flood attacks upholds the concept of Availability from the Confidentiality, Integrity and Availability (CIA) Triad security standard (Anderson, 2020).

```
        : 3
Enter artefact title: Disco Cat
Enter artefact artist / creator: Komiku
Enter the file path: "C:\Users\matth\OneDrive\Desktop\Disco Cat - Komiku.wav"
File accepted.
Disco Cat added to your artefacts.
--------------------------------------
What would you like to do?:
        1) View My Artefact Library.
        2) Access an Artifact.
        3) Add Artefact.
        4) Modify Artefact.
        5) Delete an Artefact.
        6) Update Details.
        7) Delete Account
        8) Log Out.
        : 1
Your stored artefacts:


--------------------------
Disco Cat
by:  Komiku
File type:  .wav
Last modified:  2025-06-09, 12:27
```

```
Enter artefact title: Excel Sheet
Enter artefact artist / creator: matt
Enter the file path: "C:\Users\matth\OneDrive\Desktop\Copy of 12-5-25.xlsx"
File not accepted.
Check for file type and size.
```



Once passing the file check an artefact in encrypted, given a checksum and a timestamp. The owner of the file is the uploader. These details are stored in the database. Encryption follows OWASP control C2: Use Cryptography to Protect Data (OWASP, 2024). Checksums protect the integrity of data, upholding the CIA triad (Anderson, 2020).

Once stored, a list of the user's artefacts can be viewed:

```
Your stored artefacts:


--------------------------
Disco Cat
by:  Komiku
File type:  .wav
Last modified:  2025-06-09, 12:27
--------------------------
Canon Score
by:  Pachelbel
File type:  .pdf
Last modified:  2025-06-09, 12:36
```

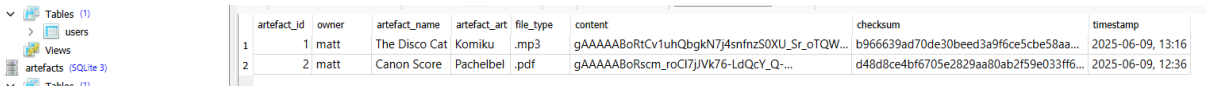
Artefacts can be accessed and played or viewed in app; this will need to be demonstrated live.

Artefacts can be modified:

```
Enter name of the artefact to update: Disco Cat
What would you like to update?:
                1) Update Artefact Name.
                2) Update Artefact Artist.
                3) Update Content.
                : 1
Enter new Artefact Name: The Disco Cat
Artefact Updated.
--------------------------------------
What would you like to do?:
        1) View My Artefact Library.
        2) Access an Artifact.
        3) Add Artefact.
        4) Modify Artefact.
        5) Delete an Artefact.
        6) Update Details.
        7) Delete Account
        8) Log Out.
        : 1
Your stored artefacts:


--------------------------
The Disco Cat
by:  Komiku
File type:  .wav
Content Last modified:  2025-06-09, 12:27
```

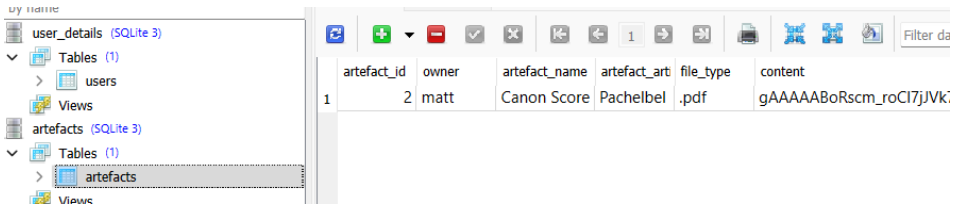
```
Enter name of the artefact to update: The Disco Cat
What would you like to update?:
                1) Update Artefact Name.
                2) Update Artefact Artist.
                3) Update Content.
                : 3
Enter the file path: "C:\Users\matth\OneDrive\Desktop\Ghosts.mp3"
File accepted.
Artefact Updated.
--------------------------------------
What would you like to do?:
        1) View My Artefact Library.
        2) Access an Artifact.
        3) Add Artefact.
        4) Modify Artefact.
        5) Delete an Artefact.
        6) Update Details.
        7) Delete Account
        8) Log Out.
        : 1
Your stored artefacts:


-------------------------
The Disco Cat
by:  Komiku
File type:  .mp3
Content Last modified:  2025-06-09, 13:16
```

When artefacts names or artists names are modified, they are changed in the database. When content is modified the file is encrypted, and both a new checksum and timestamp are created.



	artefact_id	owner	artefact_name	artefact_art	file_type	content	checksum	timestamp
1	1	matt	The Disco Cat	Komiku	.mp3	gAAAAABoRtCv1uhQbgkN7j4snfnzS0XU_Sr_oTQW...	b966639ad70de30beed3a9f6ce5cbe58aa...	2025-06-09, 13:16
2	2	matt	Canon Score	Pachelbel	.pdf	gAAAAABoRscm_roCI7jJVk76-LdQcY_Q-...	d48d8ce4bf6705e2829aa80ab2f59e033ff6...	2025-06-09, 12:36

Users can delete their own artefacts.




```
        : 5
Enter the name of the artefact you wish to delete: The Disco Cat
The Disco Cat removed from your library.
```

Users can modify their user details and delete their account.

```
Select field to amend: 1) username 2) password  3) email : 1
New username: Matthew Banks
username updated.
```

	user_id	username	password	email	role
1	1	murray2012	$2b$12$ILPIW/0ThjmxajhX9ixqBeDSSdLf400tMUiJPYCH6pTB6UpzCR4M2	ssdsecureenclaveapp@gmail.com	admin
2	2	Matthew Banks	$2b$12$PAnl8Xq1jMrs1zFCaoRGL.mrMKI7go4CkwqU/k253h/odqYUZUqKK	ssdsecureenclaveapp@gmail.com	user

	artefact_id	owner	artefact_name	artefact_arti	file_type	content
1	2	Matthew Banks	Canon Score	Pachelbel	.pdf	gAAAAABoRscm_roCI7jJVk76-L
2	3	Matthew Banks	Disco Cat	Komiku	.wav	gAAAAABoRt6Ux1UfuUJZ60AJx

```
        7) Delete Account
        8) Log Out.
        : 7
Are you sure you want to delete your account?  This will also delete all artefacts related to your account. (Y or N) : Y
Matthew Banks account removed.


Matthew Banks artefacts removed.
```

	user_id	username	password	email	role
1	1	murray2012	$2b$12$ILPIW/0ThjmxajhX9ixqBeDSSdLf400tMUiJPYCH6pTB6UpzCR4M2	ssdsecureenclaveapp@gmail.com	admin

Deleting a user account removes their details and any artefacts associated with the user from the system. They are immediately logged out. Removal of user data is required under article 17 of the UK General Data Protection Regulation (UKGDPR) (UKGDPR, 2018, art.17).

Admin Options

Admin users can perform all the same functions as a regular user through class inheritance in the python code. They also have extra options for moderation purposes. They can view a list of all users and artefacts and can access all artefacts to check for content policy violations (needs to be demonstrated live).

```
The current list of users:

----------------------------

Username:  murray2012

Email address:  ssdsecureenclaveapp@gmail.com

Role:  admin

----------------------------

----------------------------

Username:  matt

Email address:  ssdsecureenclaveapp@gmail.com

Role:  user

----------------------------
```

```
        : 8
-----------------------------
Disco Cat
by:  Komiku
Owner:  matt
File type:  .wav
Last modified: 2025-06-09, 14:55
-----------------------------

-----------------------------
Canon Score
by:  Pachelbel
Owner:  matt
File type:  .pdf
Last modified: 2025-06-09, 14:55
-----------------------------

-----------------------------
Castle in the Cloud
by:  TRG
Owner:  murray2012
File type:  .mp3
Last modified: 2025-06-09, 14:58
-----------------------------
```

They can change the role of any user between ‘user’ and ‘admin’. This is the only detail of other users they are permitted to change.

```
Enter the username of the user whose role you want to update: matt
Set role to admin or user? : admin
matt role updated.
```

	user_id	username	password	email	role
1	1	murray2012	$2b$12$ILPIW/0ThjmxajhX9ixqBeDSSdLf400tMUiJPYCH6pTB6UpzCR4M2	ssdsecureenclaveapp@gmail.com	admin
2	2	matt	$2b$12$rPW3KVJhdOnQg9TCRc8tOOiZEt/A.kF8VaJog95Dc3VBwnwnWYfHu	ssdsecureenclaveapp@gmail.com	admin

They can delete any content and delete any user from the application.

```
Enter username of the artefact to delete: matt
Enter name of the artefact to delete: Disco Cat
Disco Cat removed from matt s library.
```

1	2	matt	Canon Score	Pachelbel	.pdf	gAAAAABoRuffy9pFS70JKLcOsO9nnn_4CDY4GKHIptXVGvv
2	3	murray2012	Castle in the Cloud	TRG	.mp3	gAAAAABoRuhxoL2nwq1BUnG0wX4Ni_oGRBrU1QV0SXLN

```
Enter the username you wish to delete.  This will permanently remove them and any artefacts related to this username from the app: matt
matt account removed.


matt artefacts removed.
```

	user_id	username	password
1	1	murray2012	$2b$12$ILPIW/0ThjmxajhX9ixqBeDSSdLf400tMUiJPYCH6pTB6UpzCR4I

Code Testing

Static code analysis was conducted with Pylint, Flake8 and Bandit.

Pylint

Pylint tests for code functionality and comments on style adherence to the PEP8 style guide recommended for Python (The Pylint Developers, 2025). It was run on the application's Python files with the command *.py. The applications code is given a grade out of 10.

```
(.venv) PS C:\Users\matth\PycharmProjects\SecureEnclave> pylint *.py
************* Module classfile
classfile.py:39:4: R0913: Too many arguments (6/5) (too-many-arguments)
classfile.py:39:4: R0917: Too many positional arguments (6/5) (too-many-positional-arguments)
classfile.py:282:12: C0200: Consider using enumerate instead of iterating with range and len (consider-using-enumerate)
classfile.py:578:4: W0246: Useless parent or super() delegation in method '__init__' (useless-parent-delegation)
classfile.py:578:4: R0913: Too many arguments (6/5) (too-many-arguments)
classfile.py:578:4: R0917: Too many positional arguments (6/5) (too-many-positional-arguments)
classfile.py:632:4: R0912: Too many branches (15/12) (too-many-branches)
classfile.py:833:12: C0200: Consider using enumerate instead of iterating with range and len (consider-using-enumerate)
classfile.py:983:0: R0902: Too many instance attributes (8/7) (too-many-instance-attributes)
classfile.py:985:4: R0913: Too many arguments (9/5) (too-many-arguments)
classfile.py:985:4: R0917: Too many positional arguments (9/5) (too-many-positional-arguments)
classfile.py:983:0: R0903: Too few public methods (0/2) (too-few-public-methods)
************* Module functions
functions.py:32:0: R1710: Either all return statements in a function should return an expression, or none of them should. (inconsistent-return-statements)
functions.py:92:0: R1710: Either all return statements in a function should return an expression, or none of them should. (inconsistent-return-statements)
functions.py:157:0: R1710: Either all return statements in a function should return an expression, or none of them should. (inconsistent-return-statements)
functions.py:199:0: R1710: Either all return statements in a function should return an expression, or none of them should. (inconsistent-return-statements)
************* Module user_database
user_database.py:1:0: R0401: Cyclic import (classfile -> functions) (cyclic-import)

------------------------------------------------------------------
Your code has been rated at 9.72/10 (previous run: 9.71/10, +0.01)
```

A rating of 9.71 was achieved. All comments that would have a performance impact of the code have been changed after previous tests. The remaining comments mainly relate to:

- classes being larger than Pylint prefers.
- Enumerate being preferred to I in range formatting.
- Inconsistent return statements.

These comments have minimal to no impact on current application performance and would be too time consuming to rectify for the current version but would be improved in future.

One comment has been disabled using the pylint: disable=wrong-import-order, wrong-import-position command. In classfile.py an environment message has been included to disable a welcome message from the library Pygame. This inclusion has disrupted the correct order of imported modules.

Flake8

Tests for PEP8 style guide adherence (PyCQA, 2025). The linter was tested on all files using flake8 followed by the six file names.

```
(.venv) PS C:\Users\matth\PycharmProjects\SecureEnclave> flake8 main.py functions.py artefact_database.py user_database.py classfile.py services.py
classfile.py:24:1: E402 module level import not at top of file
classfile.py:25:1: E402 module level import not at top of file
classfile.py:26:1: E402 module level import not at top of file
classfile.py:27:1: E402 module level import not at top of file
classfile.py:28:1: E402 module level import not at top of file
classfile.py:29:1: E402 module level import not at top of file
classfile.py:30:1: E402 module level import not at top of file
(.venv) PS C:\Users\matth\PycharmProjects\SecureEnclave>
```

All comments from Flake8 testing relate to the incorrect module order noted in the Pylint section. As stated, the order is necessary and so these comments will be ignored.

Bandit

Bandit is used for uncovering security weaknesses (PyCQA, 2024). Run with the command bandit followed by the six file names.

```
Run started:2025-06-09 16:11:28.390399

Test results:
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.8.3/blacklists/blacklist_calls.html#b311-random
   Location: .\functions.py:162:21
161         # email address and login key, the subject and body of the email.
162         login_code = str(random.randint(100000, 999999))
163         sender = 'ssdsecureenclaveapp@gmail.com'

--------------------------------------------------

Code scanned:
        Total lines of code: 863
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 1
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 1
Files skipped (0):
```

Bandit returned one comment of low severity – using a pseudo random generator. This generator is used for creating a verification code for the MFA login. Due to the low severity of the issue, it will remain in the current version. A more secure option would be implemented in future.

<u>Future Inclusions</u>

As well as the recommended change from the static code analysis, one future improvement would be to implement a logging system that admins could access to monitor user activity. This would implement OWASP control C9 (OWASP, 2024).

Conclusion

The application displays full CRUD functionality, whilst also containing several security features that were implemented in response to OWASP's proactive controls. Uploaded artefacts are put through a validation and security process to uphold the principles of the CIA triad. Static code analysis highlighted some minor issues that didn't affect performance or security but would be updated in future versions, alongside a logging system.

References

Anderson, R. (2020) *Security Engineering: A Guide to Building Dependable Distributed Systems*. 3rd ed. Indianapolis, Indiana: John Wiley & Sons, Inc.

Clark, A. et al. (2025) *Pillow (V11.2.1)*. Available at: https://pillow.readthedocs.io/en/stable/ (Accessed 2 June 2025).

Gaffney, K. P., et al. (2022) 'SQLite: past, present, and future'. *Proceedings of the VLDB Endowment* 15 (12), pp 3535-3547. Available at: https://doi.org/10.14778/3554821.3554842. (Accessed 7 June 2025).

Geeks for Geeks. (2022) *Password validation in Python*. Available from: https://www.geeksforgeeks.org/password-validation-in-python/ (Accessed 3 June 2025).

Odeh, N. and Hijazi, S. (2023) 'Detecting and Preventing Common Web Application Vulnerabilities: A Comprehensive Approach'. *International Journal of Information Technology and Computer Science*, 15(3), pp. 26–41. Available at: https://doi.org/10.5815/ijitcs.2023.03.03 (Accessed 5 June 2025).

OWASP Foundation. (2024) *OWASP Top Ten Proactive Controls 2024*. Available from: https://top10proactive.owasp.org/archive/2024/ (Accessed 1 June 2025).

Python Cryptographic Authority. (2025) *Bcrypt (V4.3.0)*. Available at: https://github.com/pyca/bcrypt (Accessed 2 June 2025).

Python Cryptographic Authority. (2025) *Cryptography (V45.0.3)*. Available at: https://cryptography.io/en/latest/ (Accessed 31 May 2025).

PyCQA (2024) *Bandit (V1.8.3)*. Available at: https://bandit.readthedocs.io/en/latest/ (Accessed 6 June 2025).

PyCQA (2025) *Flake8 (V7.2.0)*. Available at: https://flake8.pycqa.org/en/latest/ (Accessed 7 June 2025).

Schmidt, D. (2023). *Guide to the getPass Package*. Available at: https://cran.r-project.org/package=getPass (Accessed 1 June 2025).

Shinners, P. et al. (2000) *Pygame (V2.6.1)*. Available at: https://www.pygame.org/news (Accessed 2 June 2025).

Team PyMuPDF. (2025) *PyMuPDF (V1.26.0)*. Available at: https://pymupdf.readthedocs.io/en/latest/ (Accessed 7 June 2025).

The Pylint Developers. (2025) *Pylint (V3.3.7)* Available at: https://pylint.pycqa.org/en/stable/user_guide/usage/run.html (Accessed 2 June 2025).

United Kingdom General Data Protection Regulation (UKGDPR) (2018) *SI 2018/1055,* art.17. London: The Stationary Office. Available at: https://www.legislation.gov.uk/eur/2016/679/contents (Accessed 5 June 2025).